

Task 1 — Choose an app and research a real malware incident

Suggested topic

Paytm-style Android banking/payment apps — Cerberus Android banking Trojan

Cerberus was an Android banking Trojan designed to steal sensitive information from infected devices. It could abuse Android accessibility features, capture credentials and SMS messages, perform overlay attacks, and provide attackers with significant control over an infected device.

For your report, explain:

- Target: Android users and financial/banking applications
- Malware: Cerberus Android banking Trojan
- Primary objective: Steal credentials and financial information
- Initial infection: Typically involved malicious/masquerading Android applications and social-engineering techniques.
- Abuse: Accessibility services and other Android capabilities could allow the malware to observe or interact with applications.
- Impact: Theft of credentials, SMS/OTP information, financial information, and unauthorized access to accounts.

Report table

Category	Finding
Malware	Cerberus Android banking Trojan
Platform	Android
Target	Banking/payment users
Main objective	Credential and financial-information theft
Techniques	Overlay attacks, accessibility abuse, SMS interception
Potential impact	Account compromise and financial fraud

Task 2 — Identify 3 IoCs

Good IoC categories include:

1. File hash

Example format:

- SHA-256: <actual Cerberus sample hash>

Useful for detecting the exact malicious APK/sample with antivirus or EDR tools.

2. Malicious domain

- Domain: <actual C2 domain>

This can be checked in DNS, proxy, firewall, or SIEM logs.

3. IP address

- IP: <actual malicious IP>

The security team can search network logs for connections to the IP and potentially block it after validation.

IoC table

IoC	Type	Detection use
<actual SHA-256>	File hash	Identify malicious APK
<actual domain>	Domain	Detect/block C2 communication
<actual IP>	IP address	Search/block suspicious network traffic

Task 3 — Mitigation

1. Install applications only from trusted sources

- Users should avoid APKs from unknown websites, links received through SMS/social media, or unofficial app stores.

Why effective:

- This reduces the chance of installing a trojanized or malicious application.

2. Review application permissions

- Users should carefully examine permissions requested by an application, particularly accessibility, SMS, notification, and other sensitive capabilities.

Why effective:

- Banking malware often attempts to abuse legitimate Android capabilities to steal information or control application interactions.

3. Keep Android and security software updated

- Users should install Android security updates and keep mobile security/Google Play Protect enabled.

Why effective:

- Security updates can patch vulnerabilities, while mobile security tools can detect known malicious applications and behavior.

Task 4 — Peer review

Strength

One strength of the report is that it clearly explains the malware's behavior and its potential impact on users. The report also identifies relevant Indicators of Compromise and connects them to practical detection methods.

Area for Improvement

One area that could be improved is the explanation of the mitigation recommendations. The recommendations could include more specific technical actions, such as monitoring suspicious network connections, validating file hashes, and integrating threat intelligence into security monitoring systems.

Overall Review

The report provides a useful overview of the malware and demonstrates a good understanding of its impact. Adding more technical evidence and specific detection methods would make the analysis stronger.

Task 5 — 2-minute presentation

2-Minute Malware Analysis Presentation

Good morning everyone.

Today I am presenting my malware analysis on the Cerberus Android banking Trojan, focusing on its relevance to users of banking and payment applications.

Cerberus is a type of Android malware designed primarily to steal sensitive information from infected devices. It can abuse Android features such as accessibility services and can use techniques such as overlay attacks and SMS interception to obtain credentials and other sensitive information.

The malware can be particularly dangerous for users of financial and payment applications because attackers may attempt to steal login credentials, authentication information, and financial data. A successful infection can potentially result in account compromise and financial fraud.

During the analysis, we identified three important types of Indicators of Compromise. The first is a file hash, which can be used to identify a known malicious APK. The second is a malicious domain, which can be monitored through DNS or proxy logs. The third is a suspicious IP address, which can be searched for in firewall and network logs.

There are several ways to reduce the risk. First, users should install applications only from trusted sources and avoid suspicious APK files. Second, users should review application permissions and avoid granting

sensitive permissions unnecessarily. Third, Android devices and security software should be kept updated so that known vulnerabilities and malicious applications can be detected or prevented.

In conclusion, mobile malware can pose a serious threat to users of financial and popular applications. Combining user awareness, secure application distribution, regular updates, and IOC-based monitoring can significantly reduce the risk.

Thank you.